

Finding and Exploiting an Unused API Endpoint

Author: Moe Htet Ar Kar (Phoe Cho)

1. Vulnerability Concept & Mechanics

Unused, deprecated, or hidden API endpoints, often referred to as shadow or orphan APIs, are legacy routes that remain active on production systems after the corresponding frontend functionality has been removed or deprecated.

These endpoints may contain outdated business logic or weaker security controls than the application's current API surface.

2. Attack Vector & Exploitation Methodology

Endpoint Discovery & Content Enumeration

Perform authorized endpoint discovery using appropriate tooling and API-focused wordlists to identify undocumented or legacy routes.

Client-Side Analysis

Inspect client-side JavaScript bundles, source maps, and application network traffic to identify route definitions or API calls that are not exposed through the current user interface.

Parameter Manipulation & Business Logic Testing

Assess discovered endpoints for weaknesses in server-side validation, authorization, pricing, quantity handling, discount logic, and transaction-state verification.

3. Validation & Impact

- **Impact:** Potential financial fraud, unauthorized acquisition of products or services, abuse of legacy discount or credit mechanisms, and exposure of outdated backend functionality.
- **Validation:** Verify whether an undocumented or deprecated endpoint permits unauthorized modification of application state or bypasses required business-logic controls.

4. Remediation & Hardening

- Establish a robust API lifecycle-management process.
- Completely decommission deprecated and unused endpoints rather than merely removing frontend references.
- Maintain a comprehensive API inventory to identify shadow and orphan APIs.
- Enforce strict server-side input validation and authorization on every endpoint.
- Perform server-side price calculation and state verification rather than trusting client-supplied financial values or quantities.